Romel Revision Tests

Implementation, local results, and release checks | 24 October 2026

This report documents a local revision, not a declaration that production is updated or certified secure. No real student record was changed by these test fixtures. The full manuscript and existing Solis PDFs remain unchanged.

Evidence	Observed result	Boundary
Backend suite	378 tests; suite passed	Local Python; mocked service/network boundaries where specified
New protection tests	30 passing test methods	Real in-memory pypdf/pyzipper encryption and controlled authorization/upload tests
Migration	10 passing scenarios	Local PostgreSQL-compatible PGlite; not live Supabase
Frontend service	11 passing scenarios	Isolated actual JS module; synthetic fetch responses
Browser	14 passing scenarios	Shared dialog fixture; desktop/mobile light/dark; not real-role production sessions

Counts describe different kinds of evidence. A test method may contain several subcases. These counts must not be added together and presented as a number of real users or independent production transactions.

Where the changes appear

Student Profile document previews/downloads; Student Scholarships SOE and attachment downloads; Grantor document and applicant-report actions; Admin document previews and report exports; Root Reports & Files and Logs & Audit. Downloads now open Save Your File Password. An encrypted PDF upload opens Unlock Uploaded PDF when a password is required.

Public images, branding, and empty import/application templates remain unchanged. For a ZIP, use an AES-capable archive tool, then work with the extracted original-format file. An already encrypted PDF inside a ZIP still needs its original PDF password.

RM Tests: Expected and Observed Behavior

Each row maps to the exact unittest method listed in the traceability appendix. Pass means the controlled local assertions held; it does not mean staging or every real document reader was tested.

ID	Core Function	Expected / Observed	Status
RM-01	Anonymous / reviewer scope	Anonymous actor and unrelated grantor reviewer cannot read file.	Pass Local
RM-02	Applicant CSV safety	Leading whitespace plus formula prefix is escaped; counts remain correct.	Pass Local
RM-03	Applicant report preview	Inline preview makes no export-history or encryption call.	Pass Local
RM-04	Report preparation failure	Failed encryption does not create successful export history.	Pass Local
RM-05	CSV / image / Excel archives	AES-256 ZIP rejects absent/wrong passwords; extraction returns exact original bytes.	Pass Local
RM-06	Audit failure	No file response when preparation cannot be audited.	Pass Local
RM-07	Cross-grantor access	Unrelated grantor cannot read file; Storage is not read.	Pass Local
RM-08	Cross-student access	Student cannot read another student's file; Storage is not read.	Pass Local
RM-09	Pending Account preview gate	Downloading signup document never writes a previewed review.	Pass Local
RM-10	COR upload round trip	Encrypted original stored unchanged; private processing copy scanned; password not saved.	Pass Local
RM-11	Already encrypted originals	Original encrypted PDF is archived intact without knowing its old password.	Pass Local
RM-12	Editable PDF forms	Existing editable text field remains a form field after encryption.	Pass Local
RM-13	Expired / revoked sessions	Session rejection prevents Storage reads.	Pass Local
RM-14	Original-copy preservation	Explicit original mode uses ZIP and preserves every original byte.	Pass Local
RM-15	Headers and audit privacy	No-store/nosniff, generic filename; password excluded; version fingerprint recorded.	Pass Local
RM-16	Malformed PDF	Invalid PDF is rejected before acceptance.	Pass Local
RM-17	Mixed-password upload batch	Incorrect second password identifies its index; no files written before full validation.	Pass Local
RM-18	Upload password errors	Clear required/incorrect password correction, not automatic acceptance.	Pass Local
RM-19	Password-assisted processing	Decrypted processing PDF is readable; uploaded encrypted original remains encrypted.	Pass Local

ID	Core Function	Expected / Observed	Status
RM-20	Batch password mapping	Valid per-file mapping accepted; malformed maps rejected.	Pass Local
RM-21	Old export clients	Missing or malformed protection request is rejected with structured 422.	Pass Local
RM-22	PDF encryption configuration	Encrypted PDF reports a 256-bit key and revision 6; generic filename.	Pass Local
RM-23	PDF correct password	Correct password opens the page; source PDF stays unencrypted and unchanged.	Pass Local
RM-24	PDF wrong/missing password	The encrypted pages cannot be read without the correct password.	Pass Local
RM-25	Signed-SOE upload	Original and derivative linked through atomic RPC without retaining password.	Pass Local
RM-26	Encryption failure	Safe failure audit; no plaintext fallback and no password in audit arguments.	Pass Local
RM-27	Root audit display	Existing Root audit interface receives actor, version fingerprint, method, time and outcome.	Pass Local
RM-28	Root file identifiers	Arbitrary bucket/path payload without stored identifiers is rejected.	Pass Local
RM-29	Signed-PDF preservation	Conservative signature-marker case uses ZIP; extracted bytes match the source.	Pass Local
RM-30	Wrong-password persistence	Wrong password creates no Storage file or submission.	Pass Local

Database, Service, and Browser Evidence

ID	SQL verification	Status
RM-SQL-1	anon grants	Pass
RM-SQL-2	authenticated grants	Pass
RM-SQL-3	service_role grants	Pass
RM-SQL-4	Privileged trigger function inaccessible to client roles	Pass
RM-SQL-5	Service append/read permitted; updates and deletion denied	Pass
RM-SQL-6	Immutable trigger blocks owner row deletion	Pass
RM-SQL-7	Anonymous actual SELECT denied	Pass
RM-SQL-8	Atomic signed-SOE wrapper restricted to service role	Pass
RM-SQL-9	Signed-SOE original finalization plus derivative linked in one transaction	Pass
RM-SQL-10	Invalid processing path rejects before original finalization	Pass

ID	Frontend verification	Status
RM-FE-1	1000 fresh 32-character passwords; cryptographic random source	Pass
RM-FE-2	Download service contains no persistent password store or console logging	Pass
RM-FE-3	Cancelled download sends no request	Pass
RM-FE-4	One request; password only in POST body, not URL or headers	Pass
RM-FE-5	Mixed-password batch mappings are per-file and cleared after success	Pass
RM-FE-6	Cancelled encrypted upload clears temporary password fields	Pass
RM-FE-7	Non-password mutation failure is never retried	Pass
RM-FE-8	Concurrent encrypted-preview prompts are queued, not overwritten	Pass
RM-FE-9	Repeated click on the same pending download cannot issue a duplicate request	Pass
RM-FE-10	Navigation/page-exit cancellation aborts in-flight preparation	Pass
RM-FE-11	Cancelling a queued upload interaction clears all waiting password prompts	Pass

Browser: 1440, 1366, 1280, 1024, 768 and 390 px, each in light/dark mode; fit, no horizontal overflow, focus, 32-character password display, acknowledgment gating and cancellation. The real loading overlay is included so the prompt remains clickable. Additional upload-password/Escape and real AES-encrypted PDF.js preview tests passed, including nonblank canvas pixels. Screenshots redact even synthetic passwords. Live clipboard-history behavior is not certified.

Reproduced Findings: Not a Historical Attack Claim

Baseline commit: d61d62f7c1591a54edd2f46a1744cec45129eeeb

RM-BASE-1: Official admin export returned readable bytes without download encryption. Reproduced only by isolated source functions with synthetic data and stubbed I/O. Retest: AES-256/no-fallback tests in test_romel_download_protection.py.

RM-BASE-2: Applicant CSV retained a leading formula-prefix value. Reproduced only by isolated source functions with synthetic data and stubbed I/O. Retest: test_applicant_csv_preserves_formula_injection_protection.

No supplied evidence identifies the historical exploit payload, affected accounts, or a successful unauthorized data extraction. Do not call these tests a penetration-test certification or claim that the whole production application is vulnerability-free.

Manual Release Procedures: Still Required

Student / Grantor / Admin / Root downloads

Procedure: Use controlled real accounts and a non-production document. Save the generated password, download, open with correct password, then retry absent/wrong password. Repeat across COR, ROG, identity, profile, requirements, signed SOE, reports and inventories.

Expected / evidence gap: Protected file opens only with correct password; generic filename; private response; correct authorized content. Status: needs staging.

Live authorization matrix

Procedure: Swap resource IDs across two students and two grantors; use unrelated reviewer, anonymous, expired, revoked and Root-session-without-Root-header requests. Do not probe real unrelated users.

Expected / evidence gap: All unauthorized reads rejected before private Storage; authorized relationship still works. Status: needs staging.

Preview versus approval

Procedure: Preview all applicable signup documents. Separately try downloading without previewing. Inspect Pending Accounts and review audit.

Expected / evidence gap: Only true preview satisfies preview gate. COR/ROG/profile previews stay usable. Status: needs authenticated staging browser check.

Encrypted re-upload and signed original

Procedure: Re-upload an encrypted COR/ROG/PDF identity with correct/wrong passwords. Test two requirement PDFs with different passwords. Round-trip a genuinely digitally signed SOE and compare SHA-256 of original/extracted bytes.

Expected / evidence gap: Policy validation still runs; original bytes retained; separate private preview copy; signature validity checked separately with a real certificate tool. Status: real-document/reader test outstanding.

Reports

Procedure: Test central and section reports with non-default filters, archive tabs, empty and multipage results. Compare preview count, decrypted PDF rows and extracted CSV rows. Verify Legal landscape header/footer and repeated table headings.

Expected / evidence gap: Same complete filtered dataset and branding; preview creates no export history; protected successful export creates one. Existing report tests pass locally; real-role visual retest outstanding.

Failures and cancellation

Procedure: Cancel the password dialog, double-click Continue, fail encryption, disable audit writes in staging, navigate away, retry with a new password, and monitor object URLs and console/network.

Expected / evidence gap: No plaintext fallback; no duplicate commit from a double-click; temporary state cleared. Staging network cancellation and application-route changes need end-to-end testing.

Secret handling

Procedure: Inspect application storage, audit rows, request logs and error logs without recording a real password in test notes. Disable request-body capture in third-party observability tools.

Expected / evidence gap: No application persistence or logging of download/upload passwords; provider instrumentation configuration must be verified.

Provider/security checks

Procedure: Verify migration grants, private buckets, current RLS/Storage policies, service-role isolation, security/performance advisors and deployment versions in staging.

Expected / evidence gap: No client access to download audit table/functions. No live Supabase advisor/deployment result is claimed by this report.

Commands and Rollout

py -3.12 scripts/run-romel-tests.py

node --experimental-vm-modules scripts/test-romel-frontend.mjs

node scripts/test-romel-download-audit.mjs <path-to-pglite/dist/index.js>

powershell -NoProfile -ExecutionPolicy Bypass -File scripts/test-romel-browser.ps1

npm run test:frontend; npm run lint; npm run build

Order: apply the additive migration and verify grants, deploy backend with cryptography/pyzipper, deploy frontend, then perform the controlled staging and live smoke checks. The connected Supabase account exposed the existing project but no preview branches; no staging branch was available for the live advisor/permission run. No production migration or deployment was performed. Do not enable plaintext fallback for older clients. Local lint/build status is reported in the completion message; do not infer deployment from a passing build.

Exact Test Traceability

RM-01: backend/tests/test_romel_download_protection.py :: test_anonymous_or_unrelated_admin_denied

RM-02: backend/tests/test_romel_download_protection.py :: test_applicant_csv_preserves_formula_injection_protection

RM-03: backend/tests/test_romel_download_protection.py :: test_applicant_preview_never_records_an_export

RM-04: backend/tests/test_romel_download_protection.py :: test_applicant_protection_failure_does_not_record_export_history

RM-05: backend/tests/test_romel_download_protection.py :: test_archive_aes256_preserves_originals

RM-06: backend/tests/test_romel_download_protection.py :: test_audit_failure_withholds_file

RM-07: backend/tests/test_romel_download_protection.py :: test_cross_grantor_download_denied_before_storage_read

RM-08: backend/tests/test_romel_download_protection.py :: test_cross_student_download_denied_before_storage_read

RM-09: backend/tests/test_romel_download_protection.py :: test_download_does_not_mark_signup_preview

RM-10: backend/tests/test_romel_download_protection.py :: test_encrypted_cor_upload_preserves_original_and_separate_private_preview

RM-11: backend/tests/test_romel_download_protection.py :: test_encrypted_original_can_be_archived_without_its_old_password

RM-12: backend/tests/test_romel_download_protection.py :: test_encryption_does_not_flatten_editable_pdf_fields

RM-13: backend/tests/test_romel_download_protection.py :: test_expired_and_revoked_sessions_do_not_read_files

RM-14: backend/tests/test_romel_download_protection.py :: test_explicit_original_archive_is_byte_identical

RM-15: backend/tests/test_romel_download_protection.py :: test_headers_filename_and_audit_contain_no_password

RM-16: backend/tests/test_romel_download_protection.py :: test_malformed_pdf_rejected

RM-17: backend/tests/test_romel_download_protection.py :: test_mixed_password_batch_validates_before_writes

RM-18: backend/tests/test_romel_download_protection.py :: test_password_assisted_processing_rejects_wrong_and_missing

RM-19: backend/tests/test_romel_download_protection.py :: test_password_assisted_processing_retains_original

RM-20: backend/tests/test_romel_download_protection.py :: test_password_mapping_validation

RM-21: backend/tests/test_romel_download_protection.py :: test_password_required_for_old_clients

RM-22: backend/tests/test_romel_download_protection.py :: test_pdf_is_explicit_aes256

RM-23: backend/tests/test_romel_download_protection.py :: test_pdf_opens_with_correct_password_and_preserves_page

RM-24: backend/tests/test_romel_download_protection.py :: test_pdf_rejects_wrong_or_missing_password

RM-25: backend/tests/test_romel_download_protection.py :: test_protected_signed_soe_upload_uses_atomic_derivative_rpc

RM-26: backend/tests/test_romel_download_protection.py :: test_protection_failure_has_safe_audit_and_no_fallback

RM-27: backend/tests/test_romel_download_protection.py :: test_root_audit_shows_actor_version_and_protection

RM-28: backend/tests/test_romel_download_protection.py :: test_root_files_cannot_use_arbitrary_storage_paths

RM-29: backend/tests/test_romel_download_protection.py :: test_signed_pdf_is_not_rewritten

RM-30: backend/tests/test_romel_download_protection.py :: test_wrong_upload_password_creates_no_storage_or_submission

Machine evidence: test-results/romel-backend.json, romel-sql.json, romel-frontend.json, romel-browser.json and romel-baseline.json. Browser fixture evidence is isolated; no real-role production login is implied.